

实验表明，在CVE-2023-41991存在的版本，PerfectCheater的绕过方式依然有效。我们先来看看两种绕过方式有何不同：

关键前提：SHA256推出后，为了兼容性，当一个签名同时存在SHA1和SHA256时，CoreTrust验证SHA1但执行SHA256。

CVE-2023-41991:

影响范围：iOS 14.0Beta2—16.7 RC（20H18）和iOS 17.0

攻击者通过一系列的复杂方式构造如下的恶意签名：

类别	SHA 1签名	SHA 256签名
哈希值	Safari's	TrollStore's
签名者	Apple Inc.	Other
二进制	Safari	TrollStore

CoreTrust 验证时，发现SHA1是系统应用的值，便给予高信任，授予其所声明的所有权限。AMFI裁决后，执行了SHA256指向的二进制，因此一个恶意App可以获得想要的任意权限。

修复方式：统一TeamID，即SHA1和SHA256必须由同一签名者签发，封堵了CVE-2023-41991所利用的绕过方式。

PerfectCheater:

影响范围：iOS 14.0Beta2-17.0.1，其中新增iOS 16.7-16.7.x（不包含16.7 RC）和iOS 17.0.1

攻击者通过一系列的复杂方式构造如下的恶意签名：

类别	SHA 1签名	SHA 256签名
哈希值	Safari's	TrollStore's
签名者	Other	Other
二进制	Safari	TrollStore

CoreTrust 验证时，先验证TeamID，发现TeamID相同，符合要求。漏洞在于：CoreTrust虽然检查了SHA1和SHA256是否由同一个签名者签发，但并没有检查这个签名者的身份。然后发现SHA1是系统应用的值，便给予高信任，授予其所声明的所有权限。AMFI裁决后，执行了SHA256指向的二进制，因此一个恶意App可以获得想要的任意权限。

虽然至今此漏洞仍未修复，但因为iOS 17.0.2起，在CoreTrust验证时前一步，先验证其是否命中信任缓存。如果是，直接授予声明权限；如果否，在经由CoreTrust验证。如果仍然按照上述方式。信任缓存认为该二进制有问题，CoreTrust认为没有问题。AMFI裁决时，为了安全性，会给出偏保守的裁决。因此这种情况下，AMFI认为该二进制有问题，漏洞利用失败。因此，该漏洞仅在没有引入信任缓存的版本生效。其中16.7.x和15.8.x至今仍然接收安全维护，但15.8.x未修复CVE-2023-

41991, 且与其他重叠的CVE-2023-41991影响的版本并没有新的价值, 因此该漏洞的价值主要在于iOS16.7 (除16.7 RC) -16.7.x和iOS 17.0.1。